

MedTech Security Baseline Checker

Cloud Security Engineer / Option A

Charlotte Zhang and Nana Ge

AI infrastructure configuration review
Five controls with reproducible offline evidence

PROBLEM STATEMENT

Configuration changes need repeatable security review

AI infrastructure changes

Training buckets, identities and compute settings evolve as teams experiment.

Manual checks repeat

Reviewers collect the same configuration evidence and reconstruct context.

Evidence needs context

Missing access can hide gaps. A failed baseline still needs human interpretation.

Goal: consistent evidence and faster triage for five selected checks.

AUTOMATION OPPORTUNITY

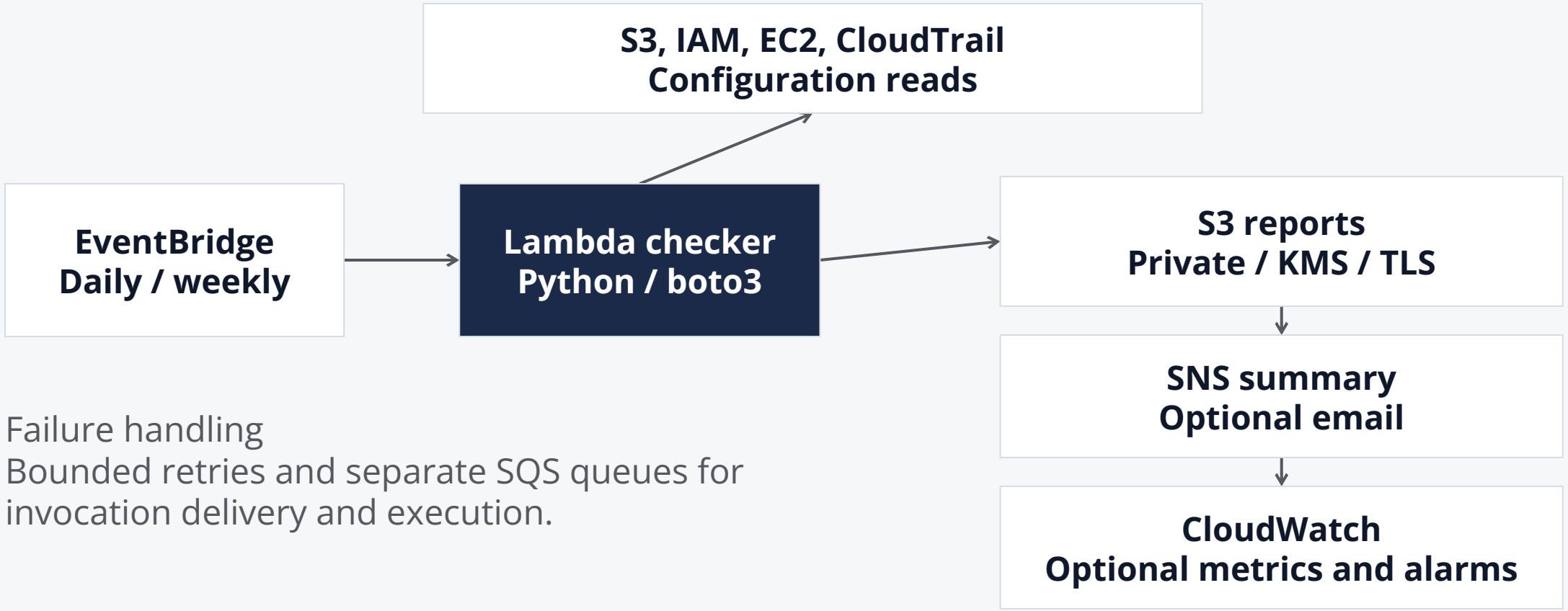
A small baseline with explicit operating boundaries

Dimension	Manual workflow	Implemented checker
Scope	Reviewer chooses resources	Explicit account, regions, buckets
Collection	Repeated console/API checks	Five repeatable control groups
Evidence	Notes and screenshots	Stable findings + JSON/MD/HTML
Uncertainty	Follow-up investigation	UNKNOWN + incomplete coverage
Review	Human interpretation	Human interpretation remains

Planning example: 15 to 5 human minutes per daily run. Assumptions on slide 10.

SOLUTION ARCHITECTURE

Read-only inspection with controlled report delivery



Failure handling
Bounded retries and separate SQS queues for invocation delivery and execution.

Cloud configuration is implemented. Schedule and outputs default to disabled.

Least privilege and explicit deployment scope

Service	Purpose	Implementation boundary
IAM + STS	Identity and read scope	Expected account; explicit resource policies
S3 + KMS	Store JSON and HTML	Private encrypted reports; 30-day lifecycle
SNS + SQS	Summary / failure handling	Separate publish permission and queues
CloudWatch	Logs and optional monitoring	14-day logs; alarms have no actions
SAM + EventBridge	Deploy and schedule	One bucket/region in sample template

Pilot sequence: review scope, deploy defaults, validate reads, then enable outputs and schedule.

Five controls and evidence-based results

Control	Baseline evaluated	Failure triage
S3 public access	Four effective BPA flags enabled	HIGH
S3 encryption	Default SSE-KMS or DSSE-KMS	MEDIUM
IAM MFA	Root and console users enrolled	CRITICAL / HIGH
EC2 ingress	No /0 rule for port 22 or 3389	HIGH
CloudTrail	Active full management-event logging	HIGH

Collect → evaluate → write reports → notify → publish metrics

SSE-S3 is valid encryption. A failed preventive flag or ingress rule needs contextual review.

Missing evidence stays visible

Failure behavior

Access denied or service error:
UNKNOWN
Independent checks continue
Pagination before inventory conclusions
Unexpected errors and delivery failures raise
Retries can duplicate outputs

Security decisions

Configuration reads only
Explicit account and bucket owner checks
Offline mode blocks AWS transport
No patient-object reads or remediation
Detailed evidence stays out of SNS

Residual risks: no durable deduplication or missed-run detector; alarm actions are not configured.

Three reproducible scenarios

Scenario	PASS	FAIL	UNKNOWN	N/A
Misconfigured	0	6	0	1
Compliant	6	0	0	1
Incomplete	5	0	1	1

python -m medtech.cli demo misconfigured --out reports

Inspect evidence, notification preview and downloadable JSON/HTML.
Local backup: extract the project ZIP and open demo/index.html.

Hosted replay (owner login may be required)

DEMO / REVIEWER EVIDENCE

A critical finding with a reviewable next step

Field	Actual misconfigured-fixture result
Control / resource	IAM_MFA / root
Observed evidence	AccountMFAEnabled: 0
Status / triage	FAIL / CRITICAL
Suggested action	Enroll root MFA or verify centralized removal

SNS preview

FAIL: 6 findings, 0 unknown, 1 N/A. Detailed evidence remains in the restricted report.

Synthetic evidence only. No observed breach, real account scan or email delivery.

METRICS AND VALUE

Assumptions make the business case reviewable

5 hours / month

30 runs × (15 − 5) human minutes
66.7% less human time for these checks
$300 staff capacity at assumed $60/hour

~$0.02 / ~$4.12

Rounded-up monthly planning budgets
30 daily scans, 256 MB Arm, 30 sec/run
Before credits, taxes and exclusions

Measured offline: 88 tests pass; three scenarios match committed reports.
Pilot targets: seven expected runs, both stored reports, one confirmed notification.

Time and cost are scenario estimates, not measured AWS outcomes. Inputs, arithmetic and sources: docs/VALUE_AND_COST.md.

A staged pilot before broader scope

Stage	Action	Acceptance evidence
First	Review scope and deploy defaults	Expected account and least privilege
Next	Enable reads, reports, one recipient	Evidence, stored JSON/HTML, summary
Pilot week	Enable daily schedule; observe runs	Seven expected runs; cost/runtime review
After pilot	Add liveness and deduplication	Missing-run and duplicate exercises
Expand	More controls, accounts and regions	Matching policies, quotas and scale tests

Later checks: SageMaker settings, KMS policies, federation, RDS and CloudTrail data events.

KEY TAKEAWAYS

A working baseline checker with explicit limits

Five configuration controls
Evidence and uncertainty reviewers can inspect
A reproducible demo and staged deployment plan

Implemented and verified offline. Live AWS permissions, scheduling, delivery and cost remain pilot work.

Project code, reports and supporting calculations

Offline demo: demo/index.html / References and AI-use disclosure included in the package